

Aetheris Therapeutics S.p.A. — Audit Controlli Annex A (93 Controlli)

Dichiarazione di Applicabilità (SoA) compilata e valutata: Valutazione di pertinenza, stato d'attuazione e giustificazioni d'inclusione/esclusione per l'Audit.

Tema 5: Controlli Organizzativi (Organisational Controls - 37 Controlli)

A.5.1 Politiche per la sicurezza delle informazioni

NON CONFORME

Requisito del Controllo: Le politiche di sicurezza e le politiche tematiche specifiche devono essere definite, approvate dalla direzione, pubblicate, comunicate e riesaminate a intervalli pianificati.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.2 Ruoli e responsabilità per la sicurezza delle informazioni

NON CONFORME

Requisito del Controllo: I ruoli e le responsabilità per la sicurezza delle informazioni devono essere definiti e assegnati in base alle esigenze organizzative.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.3 Separazione dei compiti (Segregation of Duties)

NON CONFORME

Requisito del Controllo: I compiti e le aree di responsabilità in potenziale conflitto devono essere segregati per ridurre il rischio di modifiche o usi impropri non autorizzati.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.4 Responsabilità della direzione

NON CONFORME

Requisito del Controllo: La direzione deve richiedere a tutto il personale di applicare la sicurezza delle informazioni in conformità con le politiche e le procedure stabilite.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.5 Contatti con le autorità

NON CONFORME

Requisito del Controllo: L'organizzazione deve stabilire e mantenere contatti con le autorità rilevanti (es. Garante Privacy, CSIRT, forze dell'ordine).

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.6 Contatti con gruppi di interesse speciale

NON CONFORME

Requisito del Controllo: L'organizzazione deve mantenere contatti con forum di sicurezza, associazioni professionali o gruppi specializzati.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.7 Threat Intelligence (Intelligence sulle minacce)

NON CONFORME

Requisito del Controllo: Le informazioni relative alle minacce alla sicurezza delle informazioni devono essere raccolte e analizzate per produrre intelligence operativa.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.8 Sicurezza delle informazioni nel project management

NON CONFORME

Requisito del Controllo: La sicurezza delle informazioni deve essere integrata nella gestione dei progetti, indipendentemente dalla natura del progetto.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.9 Inventario delle informazioni e degli altri asset associati

NON CONFORME

Requisito del Controllo: Un inventario delle informazioni e degli altri asset associati, inclusi i relativi proprietari (Asset Owner), deve essere sviluppato e mantenuto.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.10 Uso ammissibile delle informazioni e degli altri asset

NON CONFORME

Requisito del Controllo: Devono essere identificate, documentate e attuate regole per l'uso ammissibile e le procedure di gestione delle informazioni e degli asset.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.11 Restituzione degli asset

NON CONFORME

Requisito del Controllo: Il personale e le terze parti devono restituire tutti gli asset aziendali in loro possesso al momento della cessazione o modifica del rapporto di lavoro o contratto.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.12 Classificazione delle informazioni

NON CONFORME

Requisito del Controllo: Le informazioni devono essere classificate in base ai requisiti di sicurezza dell'organizzazione (riservatezza, integrità, disponibilità) e alle esigenze degli stakeholder.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.13 Etichettatura delle informazioni

NON CONFORME

Requisito del Controllo: Deve essere sviluppato e attuato un set appropriato di procedure per l'etichettatura delle informazioni in conformità con lo schema di classificazione adottato.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.14 Trasferimento delle informazioni

NON CONFORME

Requisito del Controllo: Devono essere definite regole, procedure o accordi di trasferimento per tutti i tipi di strumenti di comunicazione interni ed esterni.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.15 Controllo degli accessi

NON CONFORME

Requisito del Controllo: Le regole per controllare l'accesso fisico e logico alle informazioni e agli asset devono essere stabilite in base ai requisiti di business e di sicurezza.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: In uso Active Directory e VPN, ma si riscontra l'assenza di MFA obbligatoria e la condivisione di credenziali amministrative (Admin).

A.5.16 Gestione delle identità

NON CONFORME

Requisito del Controllo: L'intero ciclo di vita delle identità degli utenti (creazione, modifica, disattivazione) deve essere gestito in modo sicuro.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: In uso Active Directory e VPN, ma si riscontra l'assenza di MFA obbligatoria e la condivisione di credenziali amministrative (Admin).

A.5.17 Informazioni di autenticazione

NON CONFORME

Requisito del Controllo: L'assegnazione e la gestione delle informazioni di autenticazione (es. password, chiavi, certificati) devono essere controllate da un processo formale.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: In uso Active Directory e VPN, ma si riscontra l'assenza di MFA obbligatoria e la condivisione di credenziali amministrative (Admin).

A.5.18 Diritti di accesso

NON CONFORME

Requisito del Controllo: I diritti di accesso a informazioni e sistemi devono essere forniti, riesaminati, modificati e revocati in conformità con le politiche aziendali.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: In uso Active Directory e VPN, ma si riscontra l'assenza di MFA obbligatoria e la condivisione di credenziali amministrative (Admin).

A.5.19 Sicurezza delle informazioni nelle relazioni con i fornitori

NON CONFORME

Requisito del Controllo: Devono essere definiti e attuati requisiti di sicurezza per mitigare i rischi associati all'accesso dei fornitori agli asset aziendali.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.20 Gestione della sicurezza negli accordi con i fornitori

NON CONFORME

Requisito del Controllo: I requisiti di sicurezza pertinenti devono essere stabiliti e concordati con ciascun fornitore nei contratti ufficiali.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: Ampio uso di provider Cloud/SaaS, ma i contratti non includono requisiti di sicurezza cyber né vengono effettuati audit sui fornitori.

A.5.21 Gestione della sicurezza nella catena di fornitura ICT

NON CONFORME

Requisito del Controllo: Devono essere definiti contratti e procedure per gestire i rischi di sicurezza relativi alla catena di fornitura di prodotti e servizi ICT.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: Ampio uso di provider Cloud/SaaS, ma i contratti non includono requisiti di sicurezza cyber né vengono effettuati audit sui fornitori.

A.5.22 Monitoraggio, riesame e gestione delle modifiche nei servizi dei fornitori

NON CONFORME

Requisito del Controllo: L'organizzazione deve monitorare, riesaminare e valutare regolarmente la erogazione dei servizi dei fornitori e gestire i cambiamenti.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: Ampio uso di provider Cloud/SaaS, ma i contratti non includono requisiti di sicurezza cyber né vengono effettuati audit sui fornitori.

A.5.23 Sicurezza delle informazioni per l'uso dei servizi Cloud

NON CONFORME

Requisito del Controllo: I processi di acquisizione, uso, gestione e uscita dai servizi cloud devono essere stabiliti in conformità ai requisiti di sicurezza aziendali.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: Ampio uso di provider Cloud/SaaS, ma i contratti non includono requisiti di sicurezza cyber né vengono effettuati audit sui fornitori.

A.5.24 Pianificazione e preparazione della gestione degli incidenti

NON CONFORME

Requisito del Controllo: L'organizzazione deve pianificare e preparare la gestione degli incidenti di sicurezza definendo ruoli, responsabilità e procedure di escalation.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: Manca un piano formalizzato di Incident Response (IRP), l'analisi forense e una procedura formale di escalation per il Board.

A.5.25 Valutazione e decisione sugli eventi di sicurezza

NON CONFORME

Requisito del Controllo: L'organizzazione deve valutare gli eventi di sicurezza e decidere se debbano essere classificati come incidenti di sicurezza delle informazioni.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: Manca un piano formalizzato di Incident Response (IRP), l'analisi forense e una procedura formale di escalation per il Board.

A.5.26 Risposta agli incidenti di sicurezza

NON CONFORME

Requisito del Controllo: Gli incidenti di sicurezza devono essere gestiti in conformità con le procedure documentate e valutati in modo tempestivo.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: Manca un piano formalizzato di Incident Response (IRP), l'analisi forense e una procedura formale di escalation per il Board.

A.5.27 Apprendimento dagli incidenti di sicurezza

NON CONFORME

Requisito del Controllo: Le conoscenze acquisite dall'analisi degli incidenti di sicurezza devono essere utilizzate per rafforzare i controlli e prevenire futuri eventi.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: Manca un piano formalizzato di Incident Response (IRP), l'analisi forense e una procedura formale di escalation per il Board.

A.5.28 Raccolta delle evidenze

NON CONFORME

Requisito del Controllo: L'organizzazione deve stabilire ed attuare procedure per l'identificazione, raccolta, acquisizione e conservazione delle evidenze digitali/legali.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: Manca un piano formalizzato di Incident Response (IRP), l'analisi forense e una procedura formale di escalation per il Board.

A.5.29 Sicurezza delle informazioni durante le interruzioni

NON CONFORME

Requisito del Controllo: L'organizzazione deve pianificare come mantenere la sicurezza delle informazioni a un livello adeguato durante eventi avversi o interruzioni.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.30 Prontezza dell'ICT per la continuità aziendale**NON CONFORME**

Requisito del Controllo: La prontezza dell'infrastruttura ICT deve essere pianificata, implementata, testata e verificata per garantire la continuità dei processi critici.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.31 Requisiti legali, statutari, regolamentari e contrattuali**NON CONFORME**

Requisito del Controllo: Tutti i requisiti legali, normativi e contrattuali pertinenti alla sicurezza delle informazioni devono essere esplicitamente identificati e documentati.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.32 Diritti di proprietà intellettuale**NON CONFORME**

Requisito del Controllo: Devono essere attuate procedure adeguate per garantire la conformità con le norme sui diritti di proprietà intellettuale e sull'uso dei software.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.33 Protezione dei registri (Records)**NON CONFORME**

Requisito del Controllo: I registri e i documenti aziendali devono essere protetti da perdita, distruzione, falsificazione, accesso non autorizzato e rilascio indebito.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.34 Privacy e protezione delle PII (Personal Identifiable Information)**NON CONFORME**

Requisito del Controllo: L'organizzazione deve garantire la protezione dei dati personali in conformità alle leggi applicabili (es. GDPR).

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.35 Riesame indipendente della sicurezza delle informazioni**NON CONFORME**

Requisito del Controllo: L'approccio dell'organizzazione alla gestione della sicurezza deve essere riesaminato in modo indipendente a intervalli pianificati.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.36 Conformità con politiche e standard di sicurezza

NON CONFORME

Requisito del Controllo: I manager devono verificare regolarmente che i processi e le procedure sotto la loro responsabilità siano conformi alle politiche di sicurezza.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.5.37 Procedure operative documentate

NON CONFORME

Requisito del Controllo: Le procedure operative per i sistemi e le strutture di elaborazione delle informazioni devono essere documentate e messe a disposizione del personale.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

Tema 6: Controlli sulle Persone (People Controls - 8 Controlli)

A.6.1 Screening e selezione del personale

NON CONFORME

Requisito del Controllo: I controlli di verifica sui precedenti (background check) di tutti i candidati devono essere eseguiti in conformità alle leggi e all'etica applicabili.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.6.2 Termini e condizioni di assunzione

NON CONFORME

Requisito del Controllo: I contratti di lavoro devono stipulare le responsabilità dei dipendenti e dell'organizzazione per la sicurezza delle informazioni.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.6.3 Consapevolezza, istruzione e formazione sulla sicurezza

NON CONFORME

Requisito del Controllo: Il personale dell'organizzazione e le terze parti rilevanti devono ricevere un'adeguata formazione sulla sicurezza e aggiornamenti periodici.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.6.4 Processo disciplinare

NON CONFORME

Requisito del Controllo: Deve essere formalizzato e comunicato un processo disciplinare per intraprendere azioni contro il personale che ha commesso violazioni della sicurezza.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.6.5 Responsabilità dopo la cessazione o cambio di rapporto

NON CONFORME

Requisito del Controllo: Le responsabilità e i doveri di sicurezza che rimangono validi dopo la cessazione o il cambio di impiego devono essere definiti e comunicati.

Stato SoA: In Scope (Si)

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.6.6 Accordi di riservatezza o non divulgazione (NDA)

NON CONFORME

Requisito del Controllo: Gli accordi di riservatezza o non divulgazione che riflettono le esigenze dell'organizzazione devono essere identificati, riesaminati e firmati.

Stato SoA: In Scope (Si)

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.6.7 Lavoro agile e da remoto (Remote Working)

NON CONFORME

Requisito del Controllo: Misure e politiche di sicurezza devono essere attuate per proteggere le informazioni trattate presso le sedi di lavoro da remoto.

Stato SoA: In Scope (Si)

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.6.8 Segnalazione degli eventi di sicurezza

NON CONFORME

Requisito del Controllo: L'organizzazione deve fornire un meccanismo affinché il personale possa segnalare tempestivamente gli eventi di sicurezza osservati o sospetti.

Stato SoA: In Scope (Si)

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

Tema 7: Controlli Fisici (Physical Controls - 14 Controlli)

A.7.1 Perimetri di sicurezza fisica

CONFORME

Requisito del Controllo: I perimetri di sicurezza fisica devono essere definiti e utilizzati per proteggere le aree che contengono informazioni e altri asset critici.

Stato SoA: In Scope (Si)

Giustificazione d'Audit & Note Tecniche: Applicabile: Presenza di sorveglianza TVCC 24/7, controllo ingressi e perimetro di sicurezza adeguato nei laboratori e nella sede centrale.

A.7.2 Ingresso fisico (Physical Entry)

CONFORME

Requisito del Controllo: Le aree protette devono essere protette da controlli d'accesso appropriati per garantire che solo il personale autorizzato possa accedere.

Stato SoA: In Scope (Si)

Giustificazione d'Audit & Note Tecniche: Applicabile: Presenza di sorveglianza TVCC 24/7, controllo ingressi e perimetro di sicurezza adeguato nei laboratori e nella sede centrale.

A.7.3 Messa in sicurezza di uffici, stanze e strutture

CONFORME

Requisito del Controllo: La sicurezza fisica di uffici, stanze e strutture operative deve essere progettata ed applicata in modo adeguato.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: Presenza di sorveglianza TVCC 24/7, controllo ingressi e perimetro di sicurezza adeguato nei laboratori e nella sede centrale.

A.7.4 Monitoraggio della sicurezza fisica

CONFORME

Requisito del Controllo: I locali aziendali e i perimetri di sicurezza devono essere monitorati continuamente contro gli accessi fisici non autorizzati.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: Presenza di sorveglianza TVCC 24/7, controllo ingressi e perimetro di sicurezza adeguato nei laboratori e nella sede centrale.

A.7.5 Protezione contro minacce fisiche e ambientali

NON CONFORME

Requisito del Controllo: Deve essere progettata ed applicata una protezione contro minacce fisiche e ambientali (es. incendi, allagamenti, disastri naturali).

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.7.6 Lavoro in aree protette

NON CONFORME

Requisito del Controllo: Devono essere progettate ed attuate procedure per il lavoro all'interno delle aree fisiche protette.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.7.7 Scrivania pulita e schermo pulito (Clear Desk / Clear Screen)

NON CONFORME

Requisito del Controllo: Devono essere definite ed applicate regole di scrivania pulita per le carte e regole di schermo pulito per le postazioni di lavoro.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.7.8 Posizionamento e protezione delle apparecchiature

NON CONFORME

Requisito del Controllo: Le apparecchiature devono essere posizionate in modo sicuro e protette per ridurre i rischi derivanti da minacce ambientali e accessi non autorizzati.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.7.9 Sicurezza degli asset fuori sede

NON CONFORME

Requisito del Controllo: Gli asset dell'organizzazione utilizzati all'esterno dei locali aziendali devono essere protetti considerando i rischi del lavoro fuori sede.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.7.10 Supporti di memorizzazione (Storage Media)

NON CONFORME

Requisito del Controllo: I supporti di memorizzazione devono essere gestiti, controllati, usati e smaltiti in conformità con la loro classificazione di sicurezza.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.7.11 Servizi di supporto (Utilities)

NON CONFORME

Requisito del Controllo: Le strutture e i sistemi di elaborazione delle informazioni devono essere protetti da interruzioni di corrente e altri guasti delle utenze.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.7.12 Sicurezza del cablaggio

NON CONFORME

Requisito del Controllo: I cavi di rete e di alimentazione che trasportano dati o supportano i servizi di informazione devono essere protetti da intercettazioni o danni.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.7.13 Manutenzione delle apparecchiature

NON CONFORME

Requisito del Controllo: Le apparecchiature devono essere sottoposte a corretta manutenzione per assicurarne la continua disponibilità e integrità.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.7.14 Smaltimento sicuro o riutilizzo delle apparecchiature

NON CONFORME

Requisito del Controllo: Tutti gli elementi contenenti supporti di memorizzazione devono essere verificati per garantire la bonifica dei dati prima dello smaltimento o riutilizzo.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

Tema 8: Controlli Tecnologici (Technological Controls - 34 Controlli)

A.8.1 Dispositivi utente finale (End Point Devices)

NON CONFORME

Requisito del Controllo: Le informazioni memorizzate o elaborate sui dispositivi utente finale devono essere protette da configurazioni e controlli di sicurezza.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.2 Diritti di accesso privilegiato

NON CONFORME

Requisito del Controllo: L'assegnazione e l'uso dei diritti di accesso privilegiato devono essere limitati e controllati rigorosamente.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: In uso Active Directory e VPN, ma si riscontra l'assenza di MFA obbligatoria e la condivisione di credenziali amministrative (Admin).

A.8.3 Restrizione dell'accesso alle informazioni

NON CONFORME

Requisito del Controllo: L'accesso alle informazioni e alle funzioni dei sistemi applicativi deve essere limitato in conformità con la politica di controllo accessi.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.4 Accesso al codice sorgente

N/A

Requisito del Controllo: L'accesso in lettura e scrittura al codice sorgente delle applicazioni deve essere controllato in modo rigoroso.

 **Stato SoA: Escluso (No)**

Giustificazione d'Audit & Note Tecniche: Non applicabile: Aetheris Therapeutics S.p.A. non sviluppa software in-house e non gestisce codice sorgente proprietario; l'operatività poggia su piattaforme SaaS commerciali.

A.8.5 Autenticazione sicura

NON CONFORME

Requisito del Controllo: I sistemi di autenticazione sicura (es. MFA) devono essere stabiliti in base al controllo degli accessi e alla classificazione dei dati.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: In uso Active Directory e VPN, ma si riscontra l'assenza di MFA obbligatoria e la condivisione di credenziali amministrative (Admin).

A.8.6 Gestione della capacità (Capacity Management)

NON CONFORME

Requisito del Controllo: L'uso delle risorse di sistema deve essere monitorato e regolato per garantire le prestazioni e la capacità necessarie.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.7 Protezione contro i malware

NON CONFORME

Requisito del Controllo: La protezione contro i software malevoli deve essere attuata e supportata da una tempestiva consapevolezza e gestione.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.8 Gestione delle vulnerabilità tecniche

NON CONFORME

Requisito del Controllo: Le informazioni sulle vulnerabilità tecniche dei sistemi in uso devono essere ottenute e valutate per attuare le opportune mitigazioni.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.9 Gestione della configurazione (Configuration Management)

NON CONFORME

Requisito del Controllo: Le configurazioni hardware, software, di rete e di sicurezza dei sistemi devono essere stabilite, documentate, monitorate e aggiornate.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.10 Cancellazione delle informazioni (Information Deletion)

NON CONFORME

Requisito del Controllo: Le informazioni contenute nei sistemi di elaborazione devono essere cancellate in modo sicuro quando non più necessarie.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.11 Mascheramento dei dati (Data Masking)

NON CONFORME

Requisito del Controllo: Il mascheramento dei dati deve essere utilizzato in conformità con la politica di controllo accessi e i requisiti legali/contrattuali.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.12 Prevenzione della fuga di dati (DLP)

NON CONFORME

Requisito del Controllo: Le misure di prevenzione della fuga di dati devono essere applicate ai sistemi che elaborano, memorizzano o trasmettono informazioni sensibili.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.13 Backup delle informazioni

CONFORME PARZIALE

Requisito del Controllo: Le copie di backup delle informazioni, del software e dei sistemi devono essere eseguite e testate regolarmente.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: Backup eseguiti regolarmente con test di Disaster Recovery, ma occorre implementare l'isolamento logico (AirGap) contro il ransomware.

A.8.14 Ridondanza delle strutture di elaborazione

CONFORME PARZIALE

Requisito del Controllo: Le strutture di elaborazione delle informazioni devono essere implementate con una ridondanza sufficiente a soddisfare i requisiti di disponibilità.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: Backup eseguiti regolarmente con test di Disaster Recovery, ma occorre implementare l'isolamento logico (AirGap) contro il ransomware.

A.8.15 Registrazione degli eventi (Logging)

NON CONFORME

Requisito del Controllo: I log che registrano le attività degli utenti, le eccezioni, le violazioni e gli eventi di sicurezza devono essere prodotti, conservati e protetti.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.16 Attività di monitoraggio (Monitoring)

NON CONFORME

Requisito del Controllo: I sistemi devono essere monitorati per rilevare comportamenti anomali o potenziali incidenti di sicurezza delle informazioni.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.17 Sincronizzazione dell'orologio (Clock Synchronisation)

NON CONFORME

Requisito del Controllo: Gli orologi di tutti i sistemi di elaborazione delle informazioni pertinenti devono essere sincronizzati con fonti orarie approvate.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.18 Uso di programmi di utilità privilegiati

NON CONFORME

Requisito del Controllo: L'uso di programmi di utilità che potrebbero essere in grado di sovrascrivere i controlli di sistema e applicativi deve essere limitato e controllato.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.19 Installazione di software su sistemi operativi

NON CONFORME

Requisito del Controllo: Devono essere stabiliti ed attuati processi di controllo per l'installazione di software sui sistemi operativi in produzione.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.20 Sicurezza delle reti

CONFORME

Requisito del Controllo: Le reti aziendali e i dispositivi di rete devono essere gestiti e controllati per proteggere le informazioni nei sistemi ed applicazioni.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile: Rete aziendale ben segmentata con VLAN e protetta da firewall Palo Alto Next-Gen regolarmente mantenuti.

A.8.21 Sicurezza dei servizi di rete

NON CONFORME

Requisito del Controllo: I meccanismi di sicurezza, i livelli di servizio e i requisiti di gestione di tutti i servizi di rete devono essere identificati e attuati.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.22 Segregazione delle reti

NON CONFORME

Requisito del Controllo: I gruppi di servizi di informazione, utenti e sistemi informativi devono essere segregati su reti logiche o fisiche separate.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.23 Filtraggio Web (Web Filtering)

NON CONFORME

Requisito del Controllo: L'accesso a siti web esterni deve essere gestito e filtrato per ridurre l'esposizione a contenuti malevoli non autorizzati.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.24 Uso della crittografia

NON CONFORME

Requisito del Controllo: Devono essere definite ed applicate regole per l'uso efficace della crittografia, inclusa la gestione delle chiavi crittografiche.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.25 Ciclo di vita dello sviluppo sicuro (SDLC)

N/A

Requisito del Controllo: Devono essere stabilite ed applicate regole per lo sviluppo sicuro di software e sistemi informativi.

 Stato SoA: Escluso (No)

Giustificazione d'Audit & Note Tecniche: Non applicabile: Aetheris Therapeutics S.p.A. non sviluppa software in-house e non gestisce codice sorgente proprietario; l'operatività poggia su piattaforme SaaS commerciali.

A.8.26 Requisiti di sicurezza delle applicazioni

N/A

Requisito del Controllo: I requisiti di sicurezza delle informazioni devono essere identificati, specificati e approvati quando si sviluppano o acquistano applicazioni.

 Stato SoA: Escluso (No)

Giustificazione d'Audit & Note Tecniche: Non applicabile: Aetheris Therapeutics S.p.A. non sviluppa software in-house e non gestisce codice sorgente proprietario; l'operatività poggia su piattaforme SaaS commerciali.

A.8.27 Architettura di sistema sicura e principi di ingegneria

N/A

Requisito del Controllo: I principi di ingegneria dei sistemi sicuri devono essere stabiliti, documentati, applicati e integrati in tutte le attività di sviluppo.

 Stato SoA: Escluso (No)

Giustificazione d'Audit & Note Tecniche: Non applicabile: Aetheris Therapeutics S.p.A. non sviluppa software in-house e non gestisce codice sorgente proprietario; l'operatività poggia su piattaforme SaaS commerciali.

A.8.28 Codifica sicura (Secure Coding)

N/A

Requisito del Controllo: I principi di codifica sicura devono essere applicati allo sviluppo del software per prevenire vulnerabilità note.

 Stato SoA: Escluso (No)

Giustificazione d'Audit & Note Tecniche: Non applicabile: Aetheris Therapeutics S.p.A. non sviluppa software in-house e non gestisce codice sorgente proprietario; l'operatività poggia su piattaforme SaaS commerciali.

A.8.29 Test di sicurezza nello sviluppo e nell'accettazione

N/A

Requisito del Controllo: I test di sicurezza devono essere definiti ed eseguiti durante il ciclo di vita dello sviluppo prima del rilascio in produzione.

 Stato SoA: Escluso (No)

Giustificazione d'Audit & Note Tecniche: Non applicabile: Aetheris Therapeutics S.p.A. non sviluppa software in-house e non gestisce codice sorgente proprietario; l'operatività poggia su piattaforme SaaS commerciali.

A.8.30 Sviluppo esternalizzato (Outsourced Development)

N/A

Requisito del Controllo: L'organizzazione deve dirigere, monitorare e riesaminare le attività di sviluppo software esternalizzate a terzi.

 Stato SoA: Escluso (No)

Giustificazione d'Audit & Note Tecniche: Non applicabile: Aetheris Therapeutics S.p.A. non sviluppa software in-house e non gestisce codice sorgente proprietario; l'operatività poggia su piattaforme SaaS commerciali.

A.8.31 Separazione degli ambienti di sviluppo, test e produzione

NON CONFORME

Requisito del Controllo: Gli ambienti di sviluppo, test e produzione devono essere separati per ridurre i rischi di accesso non autorizzato o modifiche al sistema produttivo.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.32 Gestione delle modifiche (Change Management)

NON CONFORME

Requisito del Controllo: Le modifiche ai sistemi operativi e applicativi devono essere soggette a rigorose procedure formali di change management.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.33 Informazioni di test

NON CONFORME

Requisito del Controllo: Le informazioni utilizzate per i test di sistema devono essere selezionate, protette e controllate in modo opportuno.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.

A.8.34 Protezione dei sistemi durante i test di audit

NON CONFORME

Requisito del Controllo: I test di audit e le altre attività di verifica che coinvolgono i sistemi operativi devono essere pianificati e concordati per minimizzare l'impatto.

 **Stato SoA: In Scope (Si)**

Giustificazione d'Audit & Note Tecniche: Applicabile ai fini della protezione degli asset R&D e dati PII: Controllo non ancora formalizzato o operato in modalità estemporanea ad-hoc.